

Chapter 10: Cloud Security & Virtualized Infrastructure

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Explain the **principles of cloud computing**
- Differentiate between **service** and **deployment** models
- Identify **cloud security risks** and shared responsibilities
- Apply **security controls**: IAM, encryption, DLP, monitoring
- Understand **virtualization security** and best practices

What is Cloud Computing?

Definition:

A model for on-demand access to a shared pool of configurable computing resources (e.g., servers, storage, applications).

Core Characteristics:

1. On-demand self-service
2. Broad network access
3. Resource pooling
4. Rapid elasticity
5. Measured service (pay-as-you-go)

 Enables scalable, cost-effective, and flexible IT operations.

Cloud Deployment Models

Model	Description	Example Use
Public Cloud	Infrastructure shared among multiple tenants, managed by provider	AWS, Microsoft Azure, Google Cloud
Private Cloud	Dedicated infrastructure for a single organization	VMware vCloud, OpenStack
Hybrid Cloud	Mix of public and private clouds, interoperable	Disaster recovery, burst workloads
Community Cloud	Shared by organizations with common goals	Research or government consortiums



Choose based on security, compliance, and cost requirements.



Cloud Service Models

Model	Provider Manages	Customer Manages	Example
IaaS	Networking, storage, virtualization	OS, apps, data	AWS EC2, Azure VM
PaaS	OS, runtime, middleware	Applications, data	Google App Engine, Heroku
SaaS	Entire stack (hardware → app)	User access	Office 365, Salesforce
SECaaS	Security services hosted in cloud	Configuration	Cloud-based AV, CASB, IAM, DLP

The Shared Responsibility Model

Security responsibilities are divided between **provider** and **customer**.

Responsibility	Cloud Provider	Customer
Physical Security	✓	✗
Infrastructure Patching	✓	⚠ (depends on model)
OS & App Security	⚠	✓
Identity & Access Control	✗	✓
Data Protection	⚠ Shared	⚠ Shared
Compliance / Governance	⚠ Shared	⚠ Shared

 *Cloud customers are always responsible for their data and access control.*

Cloud Security Challenges

- **Data Privacy & Compliance:** jurisdiction and legal requirements
- **Multi-tenancy:** shared resources between customers
- **Unauthorized Access:** weak IAM or misconfigurations
- **Data Breaches & Remnants:** improper deletion, cloud backups
- **Loss of Visibility:** limited monitoring of provider infrastructure

 Focus on strong IAM, encryption, and configuration management.

Cloud Security Controls

1 Identity and Access Management (IAM)

- Centralized user provisioning
- Enforce **MFA, least privilege, and role-based access control (RBAC)**
- Use **federated identity** (SAML, OAuth, OpenID Connect)
- Regularly audit user roles and tokens

2 Encryption

- Encrypt data **at rest, in transit, and in use**
- Manage keys securely using **Key Management Service (KMS)**

Encryption & Key Management

Data Encryption:

- **At Rest:** AES-256 (storage, databases)
- **In Transit:** TLS 1.2/1.3 for all connections
- **In Use:** encrypted memory and CPU registers (emerging tech)

Key Management Best Practices:

- Separate keys from encrypted data
- Rotate keys periodically
- Use HSM (Hardware Security Module) or cloud KMS
- Apply strict access control for key usage

Data Loss Prevention (DLP) in the Cloud

Definition:

DLP tools prevent sensitive data from leaving authorized environments.

Type	Focus	Example
Endpoint DLP	User device activity	Block USB or print
Network DLP	Data in motion	Scan email attachments
Cloud DLP	Data in SaaS storage	Google DLP API, Microsoft Purview

Controls:

- Classify and tag sensitive data
- Enforce encryption and policy-based blocking
- Integrate with CASB (Cloud Access Security Broker)

CASB — Cloud Access Security Broker

CASB bridges users and cloud services to enforce security policies.

Functions:

- Visibility into shadow IT cloud usage
- Access control and anomaly detection
- DLP and encryption enforcement
- Compliance reporting (HIPAA, GDPR, ISO 27017)

 Examples: Netskope, Microsoft Defender for Cloud Apps, McAfee MVISION Cloud.

Cloud Sandboxing & Threat Analysis

- Isolates suspicious files or workloads in a controlled environment
- Detects zero-day exploits and malware
- Used in:
 - Email gateways
 - Cloud storage scanning
 - API security inspection

Example: Palo Alto WildFire, FireEye Helix, AWS Malware Protection

Continuous Monitoring & Logging

Goal: maintain visibility into cloud assets and configurations.

Best Practices:

- Collect logs via **CloudTrail, Azure Monitor, Google SCC**
- Aggregate into SIEM (Splunk, Sentinel, QRadar)
- Monitor for misconfigurations (CIS Benchmarks)
- Enable alerts for IAM anomalies, unusual data transfers

Cloud Compliance Standards

- **ISO/IEC 27017:** Security controls for cloud services
- **ISO/IEC 27018:** Data protection in cloud environments
- **CSA CCM:** Cloud Controls Matrix
- **NIST SP 800-144:** Cloud Computing Security Guidelines
- **GDPR / HIPAA:** Regional privacy regulations

 Compliance frameworks define required controls for cloud providers and customers.

Virtualization Overview

Virtualization underpins most cloud infrastructures.

Concept: creating multiple virtual instances (VMs, networks, storage) on a single physical host.

Benefits:

- Resource efficiency
- Isolation
- Snapshot and cloning support
- Rapid provisioning

 *Virtualization enables elasticity and multi-tenancy.*

Hypervisors

Hypervisor: software managing virtual machines (VMs).

Type	Description	Examples
Type I (Bare-Metal)	Runs directly on hardware	VMware ESXi, Microsoft Hyper-V, XenServer
Type II (Hosted)	Runs on top of OS	Oracle VirtualBox, VMware Workstation

 Type I = production; Type II = labs or testing.

Virtualization Security Risks

Threat	Description	Mitigation
VM Escape	Attacker breaks isolation to access host	Patch hypervisors, limit admin access
Data Remnants	Data persists after VM deletion	Secure wiping, encrypted storage
Privilege Escalation	Compromise of hypervisor or admin credentials	RBAC, MFA, logging
VM Sprawl	Uncontrolled creation of VMs	Centralized inventory, lifecycle management

Securing Virtual Environments

1. Keep hypervisors and VMs updated.
2. Restrict host-to-guest communication.
3. Use **dedicated management networks**.
4. Apply **encryption** for VM storage.
5. Monitor inter-VM traffic using **virtual IDS/IPS**.
6. Enforce strong **administrative access control**.

Live Migration & Data Protection

Definition: moving a running VM between hosts without downtime.

Risks:

- Data exposure during migration
- Session hijacking
- Man-in-the-middle attacks

Controls:

- Encrypt migration traffic (TLS/IPsec)
- Isolate migration network
- Authenticate both source and destination hosts

Defense in Depth for Cloud & Virtualization

- **Identity & Access Control** (IAM, MFA, RBAC)
- **Network Segmentation** (VPCs, subnets, VLANs)
- **Encryption & DLP** for data protection
- **Logging & SIEM** for monitoring
- **Security Automation** via Infrastructure-as-Code (IaC)
- **Compliance Auditing** using cloud-native tools

Best Practices Summary

- Understand and apply the **Shared Responsibility Model**
- Use **IAM, encryption, and DLP** consistently
- Secure virtualization hosts and management interfaces
- Continuously monitor and audit configurations
- Automate patching, scanning, and compliance reporting

End of Chapter 10

Next: [Chapter 11 — Network Attacks & Intrusion Techniques](#)